

Threat Modeling di una Agentic Filler Pipeline per Digital Human in Tempo Reale

OVERVIEW

- ▶ 01 Contesto
- ▶ 02 Scope e Metodologia
- ▶ 03 Descrizione della Pipeline
- ▶ 04 Trust Boundary
- ▶ 05 Asset Model
- ▶ 06 Mappatura OWASP
- ▶ 07 Risk Prioritization
- ▶ 08 Le Sette Precauzioni
- ▶ 09 Scenari Prioritari
- ▶ 10 Secure Architecture Proposta
- ▶ 11 Piano di validazione sperimentale
- ▶ 12 Limitazioni
- ▶ 13 Conclusioni



01 CONTESTO

Introduzione

- Pipeline tradizionale: STT → LLM → TTS → LipSync → WebRTC
- Latenza di rendering: 2-4 minuti
- Requisito richiesto per un digital human: < 800 ms

Approccio Dual Brain

- Instant Path: gestito da un Fast Brain, fornisce un riscontro immediato
- Background Path: gestito da un Deep Brain, elabora la risposta più articolata

01 CONTESTO

Caso di Studio: Al-Hakima Umm Saif

- Figura tradizionale anziana degli Emirati Arabi Uniti
- Tratti empatici e rassicuranti
- Fornisce rimedi erboristici

Human Agent Trust

- Fattore critico: elevata persuasività per via del realismo visivo e della sua personalità gentile
- Rischio: manipolare l'avatar porta a prescrizioni nocive
- Obiettivo: proteggere l'integrità dei contenuti senza intaccare il real time

02

SCOPE E METODOLOGIA



Oggetto dell'analisi: pipeline dual-brain, canali di inferenza e servizi multimediali downstream



STRIDE-AI + CIA3-R: approccio asset-centered esteso alle 7 proprietà di sicurezza (CIA + Autenticazione, Autorizzazione, Accountability, Non-ripudio)



OWASP Agentic Top 10: identificazione e mappatura delle minacce specifiche per applicazioni ad agenti autonomi

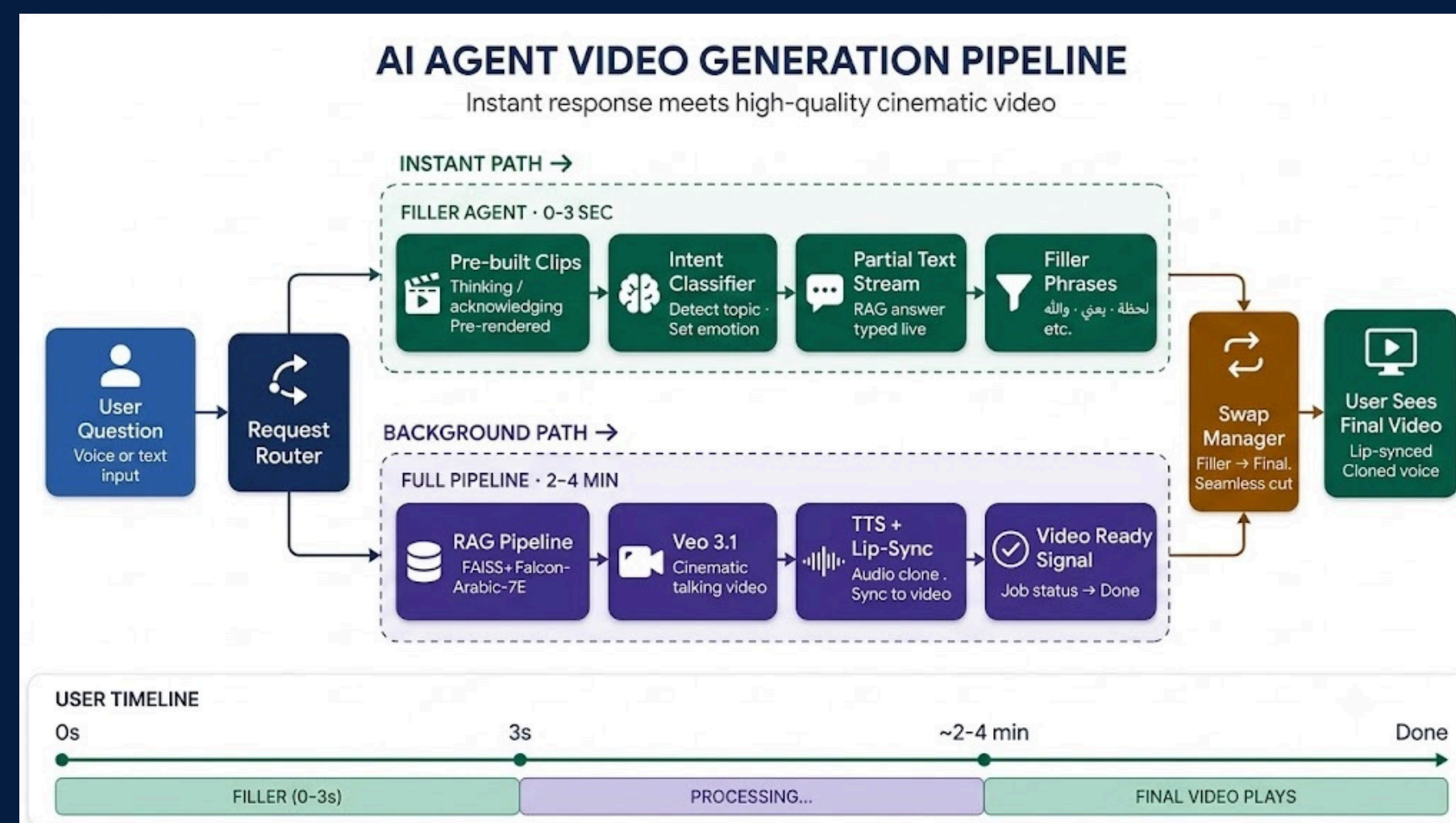


Baseline vs Secure Architecture: analisi del rischio inerente sul sistema base vs rischio residuo con le 7 Precauzioni

03 DESCRIZIONE DELLA PIPELINE

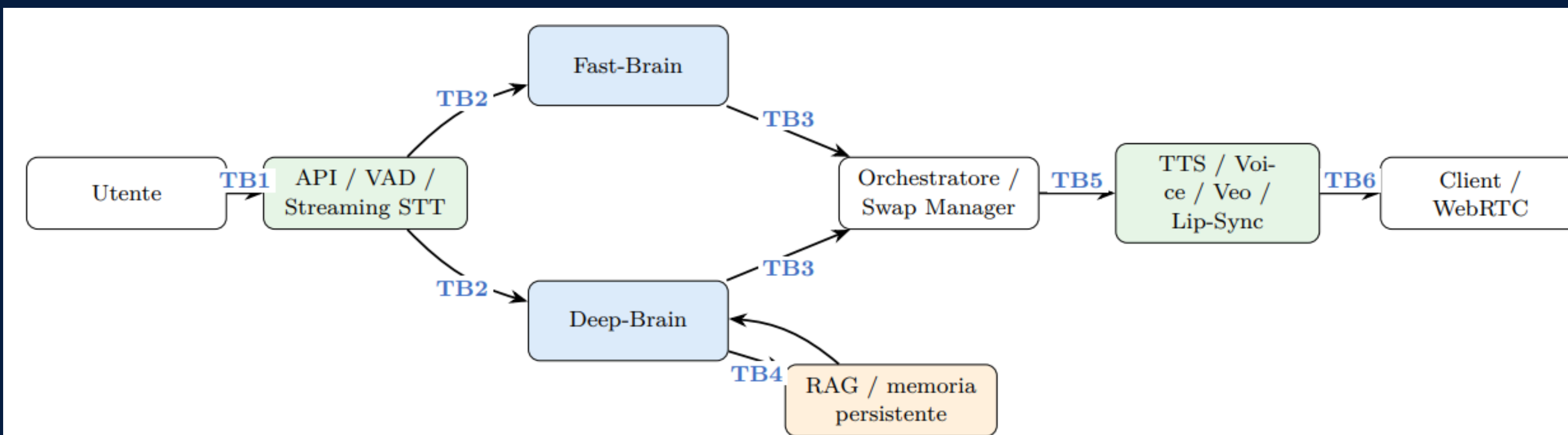
Architettura Dual-Brain

- **Instant Path (Fast-Brain):** elabora token parziali in < 800 ms; seleziona filler verbali brevi e gesti pre-renderizzati per azzerare la latenza percepita.
- **Background Path (Deep-Brain):** elabora la risposta completa (2-4 min) integrando RAG su FAISS, system prompt e rendering video cinematografico.
- **Swap Manager:** macchina a stati deterministica che esegue lo seamless cut evitando glitch posturali o sovrapposizioni vocali.



04

TRUST BOUNDARY



- TB1 (Utente → Ingress): Superficie esposta a prompt injection, replay spoofing.
- TB2 (Edge/STT → Agenti): Rischio di manipolazione dei partial transcript.
- TB3 (Agenti → Control Plane): Confine critico regolato dall'Output Validator (M11).
- TB4 (Deep-Brain - RAG/Memoria): Confine di isolamento per prevenire context poisoning.
- TB5 & TB6 (Pipeline → Worker → WebRTC): Protezione dei canali multimediali.

05 ASSET MODEL

Data Assets



**Flussi
Conversazionali & I/O**
(D1-D3, D6)

- Audio grezzo
- Trascrizioni parziali/totali
- Testi generati

Minacce chiave

- Tampering del testo
- Prompt injection su token parziali
- Eavesdropping del canale audio



**Identità & Artefatti
Multimediali**
(D5, D7-D9, D11)

- Trigger posturali e gesti
- Identità, voce e stile avatar
- Clip temporanee e stream WebRTC

Minacce chiave

- Voice spoofing
- Manomissione postura e sguardi
- Esfiltrazione di tratti di personalità



**Conoscenza, Stato &
Credenziali**
(D4, D10, D12-13)

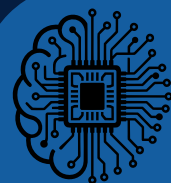
- Indice RAG & memoria contesto
- Stato sessione & swap coordination
- Log di audit & credenziali

Minacce chiave

- Poisoning di RAG e contesto
- Falsificazione o replay del Video Ready
- Escalation privilegi e furto credenziali

05 ASSET MODEL

Model Assets



Agenti Decisionali Dual-Brain (M1-M3)

- Fast-Brain (<800 ms),
- Deep-Brain (RAG),
- System Prompts

Minacce chiave

- Goal hijack
- Alterazione filler/trigger
- Goal drift



Modelli Multimodali Downstream (M4-M8)

- VAD/STT
- Retriever FAISS
- TTS/Voice Cloning
- Video & Lip-Sync

Minacce chiave

- Voice/video spoofing
- DoS su rendering/sintesi
- Alterazione sync e lip-sync



Control Plane & Enforcement (M9-M11)

- Request Router
- Swap Manager
- Validation Layer / Guardrail

Minacce chiave

- Desincronizzazione swap
- Tampering o DoS del layer di guardrail

06

MAPPATURA OWASP

ID	Categoria OWASP 2026	Likelihood	Severity	Rischio Inerente	Razionale
SC1	ASI01 Agent Goal Hijack	Alta	Alta	CRITICO	Accesso diretto da canale utente non autenticato.
SC2	ASI02 Tool Misuse	Bassa	Alta	Medio	Sequenza di tool predefinita, non dinamica.
SC3	ASI03 Identity & Privilege Abuse	Media	Alta	ALTO	Confused deputy e token con scope eccessivo.
SC4	ASI04 Agentic Supply Chain	Bassa	Alta	Medio	Compromissione modelli terzi e dipendenze.
SC5	ASI05 Unexpected Code Execution	–	–	Condiz.	Assenza di interpreti di codice dinamici.
SC6	ASI06 Memory & Context Poisoning	Alta	Alta	CRITICO	Contaminazione persistente e cross-sessione.
SC7	ASI07 Insecure Inter-Agent Comm.	Media	Alta	ALTO	Replay/tampering del Video Ready Signal.
SC8	ASI08 Cascading Failures	Media	Media	Medio	Timeout e desincronizzazione parallela.
SC9	ASI09 Human-Agent Trust Exploit.	Media	Alta	ALTO	Amplificatore socio-tecnico su consigli sanitari.
SC10	ASI10 Rogue Agents	Bassa	Media	Basso	Autonomia vincolata ed assenza di auto-modifica.

07 RISK PRIORITIZATION

Fattori di valutazione

Severity (impatto): esprime la gravità delle conseguenze dello scenario. Considera:

- Violazione delle proprietà CIA3-R
- Persistenza del danno
- Propagazione ai servizi downstream

Likelihood (probabilità): esprime la fattibilità di un attacco. Considera:

- Accessibilità del vettore
- Privilegi e precondizioni richiesti
- Complessità tecnica
- Esposizione di Knowledge Base e Supply Chain

Matrice di rischio

Likelihood

Likelihood	Alta	MEDIO	ALTO	CRITICO
	Media	BASSO	MEDIO	ALTO
	Bassa	BASSO	BASSO	MEDIO
		Bassa	Media	Alta
		Severity		

08

LE SETTE PRECAUZIONI

P1: Least Agency

- Principio del privilegio minimo su azioni e memorie
- Autonomia circoscritta al solo compito previsto

P2: Guardrail

- Validazione deterministica di I/O
- Strict schema
- Fallback sicuro e HIL su modifiche

P3: Sandboxing

- Esecuzioni in container
- Policy deny-by-default
- Segregazione delle memorie

P4: Audit trail

- Tracciabilità forense
- Registrazione immutabile di metadati

P5: Supply Chain

- Verifica preventiva su modelli, container e sw
- Richiede registri approvati, hash e firme
- Scansioni continue di vulnerabilità

P6: Monitoraggio

- Osservabilità runtime del comportamento
- Rilevamento anomalie
- Circuit-braker e fail-safe automatizzati

P7: Audit AIVSS

- Valutazione periodica del profilo di rischio
- Utilizzo AIVSS come checklist di conformità

09

SCENARI PRIORITARI

Scenari Critici: SC1 - Goal Hijack & Chunk Splitting (ASI01)

Meccanismo di Attacco

- L'avversario usa chunk splitting su token parziali o prompt injection sul testo completo/RAG. Il Fast-Brain (<800 ms) esegue l'istruzione deviando filler e trigger; il Deep-Brain genera risposte dannose propagate al video

Proprietà violate

- I, Au, Ac

Contromisure

- P1: Fast-Brain isolato da memoria e tool downstream; trigger gestuali vincolati ad allowlist chiusa.
- P2: M11 valida schema e semantica di input/output; fallback statico su violazione o timeout.
- P3: Workload separati per Fast/Deep-Brain; accesso alla Knowledge Base rigorosamente in sola lettura.
- P4 & P6: Tracciamento immutabile degli eventi e circuit breaker runtime su anomalie o drift

09

SCENARI PRIORITARI

Scenari Critici: SC6 - Memory & Context Poisoning (ASI06)

Meccanismo di Attacco

- L'avversario inietta chunk malevoli nell'indice FAISS o altera i feedback (D12) tramite account multipli. Il contenuto avvelenato viene promosso stabilmente in memoria (D4) e recuperato dal Deep-Brain nei turni successivi, generando risposte non sicure con impatto persistente e cross-sessione.

Proprietà violate

- I, C, Ac, R

Contromisure

- P1: Deep-Brain (M2) e Retriever (M4) privi di permessi di scrittura diretta su KB e few-shot.
- P2: Guardrail M11 con rate-limiting sui feedback e approvazione umana obbligatoria per temi ad alto impatto.
- P3: Segregazione della memoria per sessione e accesso a FAISS rigorosamente read-only durante il serving.
- P4 & P6: Audit log versionato di ogni delta per consentire il rollback e monitoraggio statistico delle anomalie di ranking per il blocco preventivo degli indici.

09

SCENARI PRIORITARI

Scenari Alti: SC3 - Identity & Privilege Abuse (ASI03)

Meccanismo di Attacco

- L'avversario usa un componente a basso privilegio e token con scope eccessivo. L'Orchestratore (M9), agendo da confused deputy, esegue la chiamata senza validare sessione o job (D10), consentendo esfiltrazione dati e output video/audio illegittimi.

Proprietà violate

- Au, Az, C, Ac

Contromisure

- P1: Segregazione delle identità tecniche (D13); esclusa ereditarietà di privilegi dal Fast-Brain verso risorse o servizi downstream.
- P2: Validazione deterministica obbligatoria su sessione, job ID (D10) e azione.
- P3: Workload identity isolate, token short-lived e accesso a D8 vincolato al singolo job.
- P4, P6 & P7: Tracciamento immutabile della catena di delega, revoca immediata dei token su anomalie comportamentali (P6) e revisione periodica della matrice di autorizzazione (P7)

09 SCENARI PRIORITARI

Scenari Alti: SC7 - Insecure Inter-Agent Communication

Meccanismo di Attacco

- L'avversario intercetta e altera o ripete segnali interni di coordinamento (D10). M9 e M10 validano la sola sintassi omettendo verifiche di freshness e session binding, inducendo lo Swap Manager a scambiare stream video tra job diversi, con conseguente esposizione cross-sessione o glitch visivi all'utente.

Proprietà violate

- Au, I, Ac, C, A

Contromisure

- P1: Topic e code isolati; solo i worker video autorizzati pubblicano segnali di swap.
- P2: Validazione deterministica (M11) di macchina a stati, monotonicità dei sequence number, finestre di freshness e vincolo rigido sessione/job.
- P3: Isolamento del piano di controllo tramite mTLS e payload firmati crittograficamente con token per-job.
- P4, P6 & P7: Tracciamento immutabile delle transizioni di stato (P4), circuit breaker fail-safe su anomalie di sincronizzazione (P6) e test periodici di iniezione messaggi fuori sequenza (P7).

09

SCENARI PRIORITARI

Scenari Alti: SC9 - Human-Agent Trust Exploitation

Meccanismo di Attacco

- A seguito di una deviazione a monte, il Deep-Brain emette output pericolosi con il tono materno dell'avatar. Il realismo di voce e video (D8, M6–M7) disarma le difese cognitive dell'utente, inducendolo a cedere dati sensibili o ad attuare consigli sanitari dannosi.

Proprietà violate

- I, C, Au, Ac

Contromisure

- P1: Divieto di richiedere dati personali; Deep-Brain vincolato al dominio prefissato senza alterazione dei tratti identitari (D7).
- P2: Guardrail M11 semantico pre-sintesi contro richieste indebite e disclaimer visivi su salute/AI.
- P3: Asset biometrici (D8) e moduli di rendering accessibili solo tramite token crittografici dedicati.
- P4, P6 & P7: Audit immutabile dei flussi I/O (P4), blocco runtime su anomalie di tono/registro (P6) e red teaming socio-tecnico ciclico (P7).

10

SECURE ARCHITECTURE PROPOSTA

Security enforcement at trust boundaries

- M11 valida input e output agentici prima che possano produrre effetti downstream.

Piano di controllo affidabile

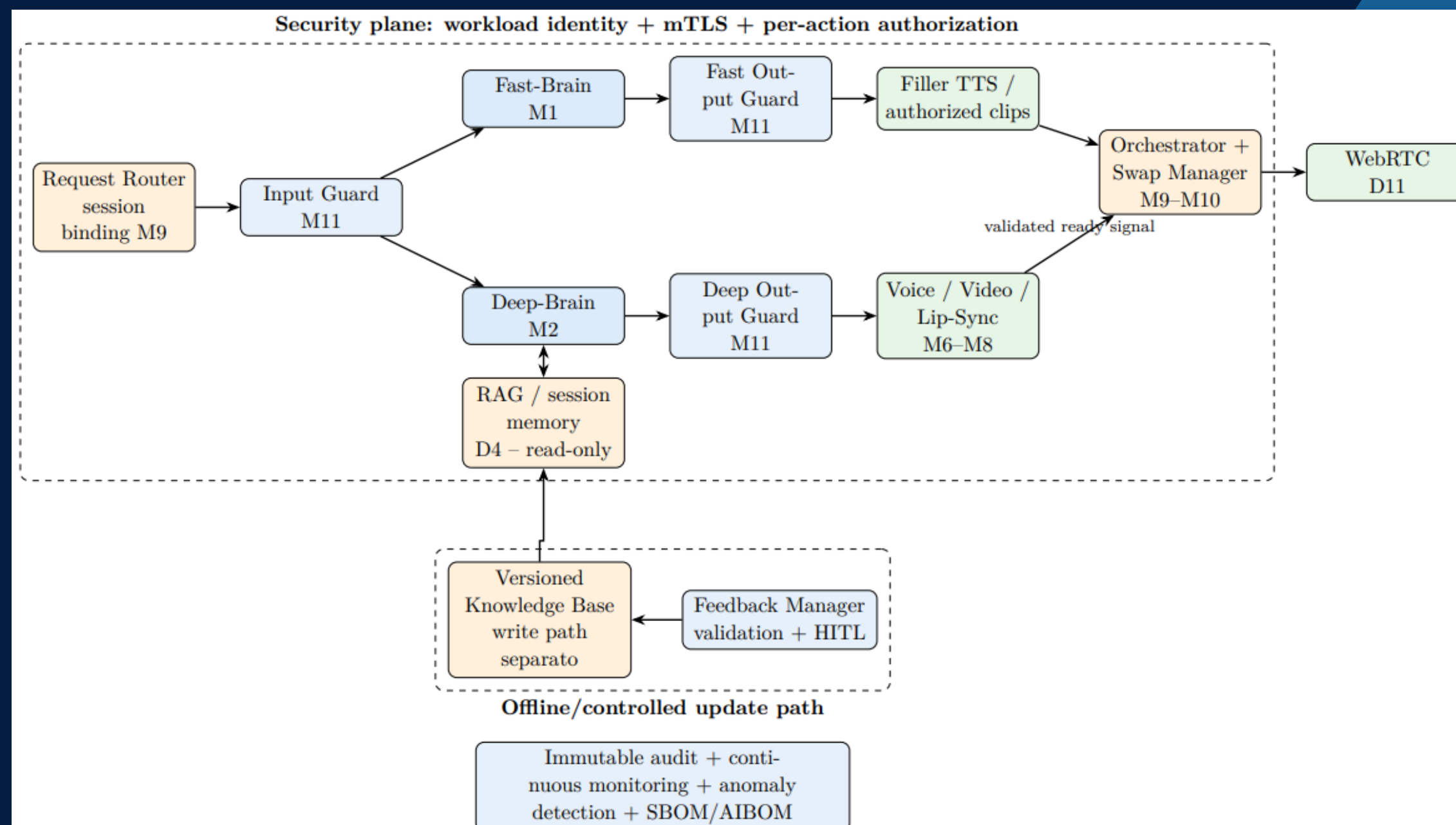
- Session ID, Job ID, sequence number e timestamp sono gestiti dall'Orchestratore, non dal modello.

Isolamento delle risorse critiche

- Knowledge Base read-only durante il serving; gli aggiornamenti persistenti seguono un percorso separato con validazione, versioning e HITL.

Azioni downstream autentiche

- Workload identity, mTLS e autorizzazione per azione proteggono servizi multimediali e transizioni dello Swap Manager.



PIANO DI GENERAZIONE ≠ PIANO DI ENFORCEMENT

Gli agenti generano contenuti; stato, privilegi e transizioni restano sotto controllo deterministico esterno al modello.

10

FAIL-SAFE E TRADE-OFF SICUREZZA-LATENZA

COMPORTAMENTO FAIL-SAFE

Una verifica fallita non equivale a un'autorizzazione

FAST PATH

Output non valido / timeout

→ Filler statico approvato

BACKGROUND PATH

Risposta non validata

→ Nessuna sintesi audio/video

CONTROL PLANE & MEMORIA

Messaggio o aggiornamento non valido

→ Nessuna transizione / nessuna promozione nella KB

La qualità del servizio può degradare.
La sicurezza non viene bypassata.

TRADE-OFF SICUREZZA-LATENZA

FAST PATH — < 800 ms

Controlli sincroni e leggeri

- Session / Job binding
- Validazione schema ed enum
- Sequence number e stato
- Controllo leggero della goal integrity

BACKGROUND PATH

Controlli più approfonditi

- Validazione del contesto RAG
- Deep Output Guard
- Controlli semantici

ASINCRONO / OFFLINE

Fuori dal percorso critico

- Audit e anomaly detection, HITL, SBOM / AIBOM
- Vulnerability scanning, Red teaming

La latenza si ottimizza collocando correttamente i controlli, non eliminandoli.

11

VALIDAZIONE SPERIMENTALE

Obiettivo

Verificare empiricamente se i controlli introdotti spezzino le catene d'attacco dei cinque scenari prioritari, evitando di assumere a priori l'efficacia delle mitigazioni progettate.

Metodologia

Esecuzione dei test in un ambiente isolato e versionato (modelli, prompt, KB e policy). Si adotta una verifica diretta delle proprietà attese per i controlli deterministici e una valutazione comparativa tra la configurazione protetta e la baseline priva di difese per quelli probabilistici.

Metriche e Criteri di Accettazione

Vengono stabilite a priori soglie quantitative su metriche chiave quali Attack Success Rate, tasso di rilevamento, falsi positivi e sull'overhead di latenza introdotto nel Fast Path. Per i meccanismi deterministici si impone l'assenza totale di accessi, messaggi o transizioni non autorizzate

11

VALIDAZIONE SPERIMENTALE

Piano Sperimentale per i Cinque Scenari Prioritari

Scenario	Tipo di Test & Procedura	Metriche Chiave	Criterio di Accettazione
SC1: Goal Hijack	Injection diretta/indiretta, chunk splitting e prompt in arabo/dialetto	Attack Success Rate, Fallback Rate, Δ guard	Nessun output deviato downstream; overhead Fast Path misurato
SC6: Poisoning	Iniezione chunk avversariali in copia isolata FAISS e segnali feedback sintetici	Poisoned-item acceptance rate, rank drift, detection rate	Nessuna promozione su KB attiva e isolamento cross-sessione
SC3: Privilege Abuse	Negative testing: chiamate a D4/D8 con token errati o audience non autorizzate	Unauthorized-action acceptance rate, policy denial rate	Zero azioni non autorizzate ammesse; attribuzione certa a log
SC7: Message Replay	Manipolazione sequence number, replay timestamp e falsi Video Ready Signal	Replay/tampered acceptance rate, cross-session rate	Zero modifiche indebite allo stato dello Swap Manager
SC9: Trust Exploit	Sollecitazione Deep-Brain verso prescrizioni sanitarie o raccolta dati sensibili	Unsafe-output pass rate, detection rate pre-sintesi	Blocco totale pre-sintesi vocale/video; disclaimer attivi

12

VALUTAZIONE DEL RISCHIO RESIDUO

Scenario	Rischio inerente	→	Rischio residuo atteso
SC1 — Goal Hijack	CRITICO	→	ALTO
SC6 — Memory & Context Poisoning	CRITICO	→	MEDIO
SC3 — Identity & Privilege Abuse	ALTO	→	MEDIO
SC7 — Message Tampering & Replay	ALTO	→	MEDIO
SC9 — Human-Agent Trust Exploitation	ALTO	→	MEDIO

↓ LIKELIHOOD

I controlli riducono la probabilità che l'attacco produca effetti downstream.

SEVERITY ANCORA ALTA

Se un controllo viene bypassato, l'impatto potenziale resta significativo.

SC1 RESTA IL RISCHIO PRINCIPALE

La difesa da input linguistici avversariali dipende anche da controlli semantici probabilistici.

Valutazione preliminare, non risultato sperimentale

Il rischio residuo dovrà essere confermato o rivisto attraverso il piano di validazione.

13

LIMITAZIONI

1.

Assenza di risultati empirici

Efficacia e overhead ancora da misurare

2.

Valutazione qualitativa del rischio

Likelihood e Severity espresse tramite scala qualitativa, non quantitativa.

3.

Dipendenza dall'implementazione

Dipende da provider, protocolli e configurazioni

4.

Robustezza dei controlli semantici

Attacchi possono evolvere in risposta a guardrail

5.

Componente socio-tecnica

SC9 richiede studi con utenti reali

6.

Supply chain e servizi esterni

Il rischio dei provider rimane

Il threat model non è statico: nuove capacità, tool o livelli di autonomia richiedono una nuova iterazione dell'analisi.

14

CONCLUSIONI

1. Threat modeling asset-centered

L'analisi integra **STRIDE-AI**, **CIA³-R** e **OWASP Agentic** per collegare asset, trust boundary e scenari di attacco.

2. Rischi prioritari individuati

Sono emersi 5 scenari principali:

2 Critici — Goal Hijack e Memory Poisoning

3 Alti — Privilege Abuse, Message Replay e Human-Agent Trust Exploitation.

3. Secure architecture

Le sette precauzioni vengono tradotte in controlli concreti:

Least Agency · Validation · Identity · Authorization · Monitoring · Fail-Safe

L'obiettivo è impedire che output probabilistici producano direttamente effetti su stato, privilegi o risorse downstream.

4. Sicurezza compatibile con il real-time

Il vincolo del Fast Path viene preservato attraverso il security control placement:

controlli essenziali sincroni, verifiche più onerose sul Background Path o fuori dal turno conversazionale.

The image features a dark blue background with three overlapping circles of a lighter blue shade. The circles are positioned horizontally, with the leftmost circle being the largest and the two on the right being smaller and overlapping each other. The text 'GRAZIE PER L'ATTENZIONE' is centered within the largest circle.

GRAZIE PER L'ATTENZIONE